# Actividad 4. Preparación y presentación del informe de certificación

**ISY1102 · EA2 · IL2.4 · Cuidarte+ · Antonella Cuvertino y Miriam Hammami.** Documento de preparación individual para estudiar y defender los resultados del trabajo compartido. Cada estudiante debe sostener el dictamen con sus propias palabras.

## 1. Resumen ejecutivo

**Dictamen: NO CERTIFICADO.** Alcance: API de autenticación, usuarios/roles, exámenes, PDF y auditoría; carga breve y análisis estático según evidencias. Dos defectos críticos permiten escalamiento de médico a administrador y eliminación anónima. No se recomienda producción con datos de salud.

## 2. Métricas de ejecución

| Indicador | Valor real |
|---|---|
| Casos maestros diseñados | 8; no todos ejecutados integralmente |
| Checkpoints API diseñados | 12 |
| Checkpoints API ejecutados | 12 (100% de esa suite) |
| PASS | 6 (50% de ejecutados) |
| FAIL | 6 |
| BLOCKED en suite API | 0 |
| Casos maestros SQLi / WCAG | Pendientes; no incluidos como PASS |
| Carga breve separada | 1 ejecutada, FAIL; p95 8698 ms |

Los números 50, 48 y 42 de la guía son ejemplos y no datos del proyecto. El lote de carga, el análisis estático y la UI histórica no se suman al denominador de doce checkpoints.

## 3. Gestión de defectos

| ID | Nivel | Hallazgo | Estado |
|---|---|---|---|
| DEF-001 | GRAVE / Alta | Auditoría sin origen IP | Abierto; sin retest de cierre |
| DEF-002 | GRAVE / Alta | Contraseñas en texto claro | Abierto; sin retest de cierre |
| DEF-003 | GRAVE / Alta | Eliminación física de exámenes | Abierto; sin retest de cierre |
| DEF-004 | GRAVE / Alta | Latencia fuera de criterio | Abierto; sin retest de cierre |
| DEF-005 | CRÍTICO | Escalamiento de médico a administrador | Abierto; sin retest de cierre |
| DEF-006 | CRÍTICO | Eliminación de usuario sin autenticar | Abierto; sin retest de cierre |

## 4. Matriz de trazabilidad

| Requisito | Caso | Resultado |
|---|---|---|
| RF-1.1 | CP-API-001 | PASS |
| RF-1.1 | CP-API-002 | PASS |
| RF-3.1 | CP-API-003 | PASS |
| NFR-SEG-4 | CP-API-004 | PASS |
| NFR-SEG-9 | CP-API-005 | PASS |

| Requisito | Caso | Resultado |
|---|---|---|
| RF-3.1; RF-4.3/4.4 | CP-API-006 | PASS |
| RF-3.3 | CP-API-007 | FAIL |
| NFR-SEG-2 | CP-API-008 | FAIL |
| RF-5.1 | CP-API-009 | FAIL |
| NFR-SEG-4 | CP-API-010 | FAIL |
| NFR-PERF-1 | CP-API-011 | FAIL |
| NFR-SEG-4 | CP-API-012 | FAIL |

## 5. Evaluación de riesgos

Riesgos mitigados por corrección en esta sesión: ninguno, porque la actividad evalúa sin modificar código. Controles observados: rechazo de credenciales/JWT inválidos e IDOR en las rutas probadas. Riesgos residuales: seis defectos abiertos, autorización en otras rutas, auditoría sin protección integral demostrada, ausencia de cobertura instrumentada, DAST y validación WCAG. Riesgos aceptados formalmente: ninguno; no existe aprobación documentada para aceptar críticos.

## 6. Conclusión y recomendación final

El criterio exige cero críticos/graves abiertos y ejecución completa del alcance de alto riesgo. Se detectaron dos críticos y cuatro graves; el criterio no se cumple. Primero corregir autorización de usuarios y roles, luego contraseñas, conservación, auditoría y latencia. Después retest y regresión con evidencia por versión; ampliar a ERS, DAST, WCAG y carga sostenida antes de reevaluar certificación. La recomendación protege confidencialidad y continuidad de datos de salud y no atribuye multas automáticas por cada defecto.